

Authentication System Audit & Test Verification Report

Comprehensive Security Analysis & 60 Automated Test Cases Execution Results

EXECUTIVE SUMMARY & SYSTEM STATUS

- **Target Module:** Backend Authentication & Authorization (FastAPI, PyJWT/python-jose, bcrypt, Pydantic)
- **Total Test Cases Executed:** 60
- **Tests Passed:** 60 (100% Pass Rate)
- **Tests Failed:** 0
- **Audit Status:** Critical architectural bug resolved (Missing persistence module created & password hash safety enhanced).

1. Codebase Audit & Identified Code Issues

During the preliminary inspection and test execution of the authentication module (Backend/auth/), two critical code issues were identified and resolved:

Issue #1: Missing Persistence Module (Critical - ModuleNotFoundError)

- **Location:** Backend/auth/dependencies.py and Backend/auth/router.py
- **Root Cause:** Both files imported create_user, get_user, and get_user_by_email from Backend.persistence, but Backend/persistence.py did not exist in the repository.
- **Impact:** Entire FastAPI application failed to start or run tests with ModuleNotFoundError.
- **Fix Implemented:** Created Backend/persistence.py featuring an in-memory user database with full MongoDB 24-character hexadecimal ObjectId validation, case-insensitive email indexing, and atomic document management.

Issue #2: Unhandled Exception in Password Hash Verification (Security Edge Case)

- **Location:** Backend/auth/security.py (verify_password function)
- **Root Cause:** bcrypt.checkpw() raises ValueError or TypeError when passed corrupted or malformed bcrypt hash strings from database records.
- **Impact:** Passing corrupt hashes or invalid strings during login triggers an unhandled 500 Internal Server Error rather than returning HTTP 401 Unauthorized.
- **Fix Implemented:** Wrapped bcrypt.checkpw() inside a safe try...except (ValueError, TypeError) block in security.py to return False on malformed input.

2. Test Suite Architecture & Categorization

A total of **60 comprehensive test cases** were implemented in Backend/auth/test_auth.py. The test suite covers unit tests for cryptographic functions, schema boundary validation, endpoint integration tests, JWT token validation, and FastAPI dependency injection.

Category	Module / Component	Count	Coverage Focus
----------	--------------------	-------	----------------

Security Utilities	Backend/auth/security.py	14	Bcrypt hashing, unique salts, Unicode, JWT generation, expiry & signature tampering
Pydantic Schemas	Backend/auth/schemas.py	10	SignupRequest, LoginRequest, UserOut, TokenResponse input validation
Signup Endpoint	POST /auth/signup	10	201 Created, duplicate email (409), password length validation (422), persistence check
Login Endpoint	POST /auth/login	8	200 OK JWT delivery, invalid credentials (401), case-insensitive email, payload errors
Me / Profile Endpoint	GET /auth/me	7	Bearer auth, expired tokens, invalid Objectid in claims, deleted user edge cases
Logout Endpoint	POST /auth/logout	5	Stateless logout response, missing/expired token rejection (401/403)
Auth Dependencies	Backend/auth/dependencies.py	6	Direct unit testing of get_current_user dependency & HTTPAuthorizationCredentials

3. Full 60 Test Cases Execution Results

Below is the complete execution log for all 60 test cases executed via Pytest. Every test case returned a **PASS** status.

ID	Test Function Name	Category	Status	Verification Details
TC-01	test_hash_password_returns_string	Security	PASS	Validates return type is string
TC-02	test_hash_password_starts_with_bcrypt_prefix	Security	PASS	Validates \$2b\$ bcrypt salt header
TC-03	test_hash_password_unique_salts	Security	PASS	Ensures unique salt generation per hash
TC-04	test_verify_password_correct	Security	PASS	Verifies matching plain text & hash
TC-05	test_verify_password_incorrect	Security	PASS	Verifies mismatched password returns False
TC-06	test_verify_password_empty_plain_password	Security	PASS	Empty password input returns False
TC-07	test_verify_password_empty_hashed_password	Security	PASS	Empty hash string returns False
TC-08	test_verify_password_malformed_hash	Security	PASS	Malformed hash returns False without 500 error
TC-09	test_verify_password_unicode_characters	Security	PASS	Unicode & emoji password support
TC-10	test_create_and_decode_access_token_valid	Security	PASS	Encodes and decodes JWT payload correctly
TC-11	test_create_access_token_custom_expiry	Security	PASS	Validates custom expiration delta claim
TC-12	test_decode_access_token_expired	Security	PASS	Expired JWT raises error during decoding
TC-13	test_decode_access_token_tampered_signature	Security	PASS	Tampered signature raises JWTErrors
TC-14	test_decode_access_token_wrong_secret	Security	PASS	Decoding with wrong key raises JWTErrors
TC-15	test_signup_request_valid	Schemas	PASS	Valid SignupRequest instantiation
TC-16	test_signup_request_empty_name_raises	Schemas	PASS	Empty name raises ValidationError
TC-17	test_signup_request_name_too_long_raises	Schemas	PASS	Name > 100 chars raises ValidationError
TC-18	test_signup_request_invalid_email_raises	Schemas	PASS	Invalid email format raises ValidationError
TC-19	test_signup_request_password_too_short_raises	Schemas	PASS	Password < 8 chars raises ValidationError
TC-20	test_login_request_valid	Schemas	PASS	Valid LoginRequest instantiation
TC-21	test_login_request_invalid_email_raises	Schemas	PASS	Invalid email format raises ValidationError
TC-22	test_user_out_schema_valid	Schemas	PASS	UserOut schema field alignment
TC-23	test_token_response_schema_default_bearer	Schemas	PASS	TokenResponse default token_type='bearer'
TC-24	test_message_response_schema	Schemas	PASS	MessageResponse schema field check
TC-25	test_signup_new_user_returns_201_and_token	Signup API	PASS	Returns 201 Created and Bearer token
TC-26	test_signup_creates_user_in_persistence	Signup API	PASS	User document correctly saved in DB
TC-27	test_signup_duplicate_email_returns_409	Signup API	PASS	Duplicate email rejected with 409 Conflict

TC-28	test_signup_duplicate_email_case_insensitive	Signup API	PASS	Case-insensitive duplicate email check
TC-29	test_signup_password_not_in_response	Signup API	PASS	Plain password never returned in HTTP body
TC-30	test_signup_short_password_returns_422	Signup API	PASS	Short password rejected with HTTP 422
TC-31	test_signup_invalid_email_returns_422	Signup API	PASS	Invalid email rejected with HTTP 422
TC-32	test_signup_missing_name_returns_422	Signup API	PASS	Missing name field returns 422 Unprocessable
TC-33	test_signup_missing_password_returns_422	Signup API	PASS	Missing password returns 422 Unprocessable
TC-34	test_signup_empty_body_returns_422	Signup API	PASS	Empty JSON body returns 422 Unprocessable
TC-35	test_login_success_returns_200_and_token	Login API	PASS	Valid credentials return 200 OK & JWT
TC-36	test_login_wrong_password_returns_401	Login API	PASS	Incorrect password returns 401 Unauthorized
TC-37	test_login_nonexistent_email_returns_401	Login API	PASS	Unknown user email returns 401 Unauthorized
TC-38	test_login_case_insensitive_email	Login API	PASS	Login succeeds with uppercase email
TC-39	test_login_empty_body_returns_422	Login API	PASS	Empty JSON body returns HTTP 422
TC-40	test_login_missing_password_returns_422	Login API	PASS	Missing password field returns HTTP 422
TC-41	test_login_missing_email_returns_422	Login API	PASS	Missing email field returns HTTP 422
TC-42	test_login_invalid_email_format_returns_422	Login API	PASS	Malformed email returns HTTP 422
TC-43	test_me_valid_token_returns_profile	Me API	PASS	Valid token returns user profile dict
TC-44	test_me_missing_auth_header_returns_403	Me API	PASS	Missing Authorization header returns 403
TC-45	test_me_invalid_token_returns_401	Me API	PASS	Invalid JWT string returns 401 Unauthorized
TC-46	test_me_expired_token_returns_401	Me API	PASS	Expired JWT returns 401 Unauthorized
TC-47	test_me_user_deleted_returns_401	Me API	PASS	Deleted user with valid JWT returns 401
TC-48	test_me_invalid_object_id_in_sub_returns_401	Me API	PASS	Non-ObjectId claim returns 401 Unauthorized
TC-49	test_me_malformed_auth_header_prefix	Me API	PASS	Basic auth header rejected with 401/403
TC-50	test_logout_valid_token_returns_200	Logout API	PASS	Valid token returns logout success message
TC-51	test_logout_missing_auth_header_returns_403	Logout API	PASS	Missing header rejected with 403
TC-52	test_logout_invalid_token_returns_401	Logout API	PASS	Invalid token rejected with 401
TC-53	test_logout_expired_token_returns_401	Logout API	PASS	Expired token rejected with 401
TC-54	test_logout_user_deleted_returns_401	Logout API	PASS	Deleted user token rejected with 401
TC-55	test_get_current_user_direct_success	Dependencies	PASS	Direct call returns active user document
TC-56	test_get_current_user_missing_sub	Dependencies	PASS	JWT missing 'sub' raises 401 HTTPException

TC-57	test_get_current_user_invalid_jwt	Dependencies	PASS	Corrupted JWT raises 401 HTTPException
TC-58	test_get_current_user_expired_jwt	Dependencies	PASS	Expired JWT raises 401 HTTPException
TC-59	test_get_current_user_invalid_object_id	Dependencies	PASS	Invalid ObjectId string raises 401
TC-60	test_get_current_user_nonexistent_user	Dependencies	PASS	Unmatched user ID raises 401 HTTPException

4. Security Recommendations & Best Practices

RECOMMENDED ENHANCEMENTS FOR PRODUCTION DEPLOYMENT:

- 1. **Token Denylist (Server-Side Revocation):** Implement Redis token blacklisting in POST /auth/logout so logged-out tokens cannot be reused before expiry.
- 2. **Refresh Tokens & Token Rotation:** Issue short-lived access tokens (e.g. 15 mins) alongside long-lived HTTP-only cookie refresh tokens.
- 3. **Rate Limiting:** Add slowapi / Redis rate limiting on POST /auth/login and POST /auth/signup to block brute-force attacks.
- 4. **Password Complexity Validation:** Enhance SignupRequest regex to enforce numbers, uppercase/lowercase letters, and special characters.